

RAPPORT TRYHACKME

Nmap - Further Nmap Room

Résumé

Ce rapport documente la complétion du room TryHackMe "Nmap" qui couvre les fondamentaux du scan de ports avec Nmap. Le room aborde les différents types de scans (SYN, UDP, NULL, FIN, Xmas), le Nmap Scripting Engine (NSE), et les techniques d'évasion de pare-feu.

Objectifs d'apprentissage

- Comprendre les différents types de scans Nmap
- Maîtriser les switches et options de Nmap
- Utiliser le Nmap Scripting Engine (NSE)
- Appliquer des techniques d'évasion de pare-feu
- Effectuer des scans pratiques sur une cible

Ibrahim Kakaev

Décembre 2025

Plateforme : TryHackMe

Room : Nmap (Further Nmap)

Difficulté : Facile

URL : <https://tryhackme.com/room/furthernmap>

Table des matières

1	Introduction	3
1.1	Contexte	3
1.2	Informations sur le Room	3
1.3	Concepts clés	3
2	Task 2 : Introduction	4
2.1	Questions et Réponses	4
2.2	Explication	4
3	Task 3 : Nmap Switches	5
3.1	Switches fondamentaux	5
3.2	Récapitulatif des switches importants	5
4	Task 4 : Scan Types Overview	7
4.1	Questions et Réponses	7
4.2	TCP Three-Way Handshake	7
5	Task 5 : TCP Connect Scans (-sT)	8
5.1	Questions et Réponses	8
5.2	Explication du TCP Connect Scan	8
6	Task 6 : SYN Scans (-sS)	9
6.1	Questions et Réponses	9
6.2	Explication du SYN Scan	9
7	Task 7 : UDP Scans (-sU)	10
7.1	Questions et Réponses	10
7.2	Explication du UDP Scan	10
8	Task 8 : NULL, FIN and Xmas Scans	11
8.1	Questions et Réponses	11
8.2	Explication des scans	11
9	Task 9 : ICMP Network Scanning	12
9.1	Questions et Réponses	12
9.2	Ping Sweep	12
10	Task 10 : NSE Scripts Overview	13
10.1	Questions et Réponses	13
10.2	Nmap Scripting Engine (NSE)	13
11	Task 11 : NSE Scripts - Working with the NSE	14
11.1	Questions et Réponses	14
11.2	Utilisation des scripts NSE	14
12	Task 12 : NSE Scripts - Searching for Scripts	15
12.1	Questions et Réponses	15
12.2	Recherche de scripts	15

13 Task 13 : Firewall Evasion	16
13.1 Questions et Réponses	16
13.2 Techniques d'évasion de pare-feu	16
14 Task 14 : Practical	17
14.1 Questions et Réponses	17
14.2 Commandes utilisées	17
15 Task 15 : Conclusion	18
15.1 Résumé des compétences acquises	18
15.2 Commandes essentielles à retenir	18
16 Annexes	19
16.1 Annexe A : Cheat Sheet Nmap	19
16.2 Annexe B : Ressources	19

1 Introduction

1.1 Contexte

Nmap (Network Mapper) est l'outil de scan de ports le plus utilisé dans l'industrie de la cybersécurité. Il permet d'identifier les ports ouverts, les services en cours d'exécution et les systèmes d'exploitation des machines cibles.

1.2 Informations sur le Room

Nom : Nmap (Further Nmap)

Plateforme : TryHackMe

URL : <https://tryhackme.com/room/furthernmap>

Difficulté : Facile

Nombre de Tasks : 15

Compétences : Scan de ports, énumération réseau, NSE

1.3 Concepts clés

- Chaque ordinateur dispose de **65535 ports** disponibles
- Les ports **0-1023** sont considérés comme "well-known" (ports réservés)
- Les ports permettent de diriger le trafic vers la bonne application
- Exemples : HTTP (80), HTTPS (443), SSH (22), FTP (21), SMB (445)

2 Task 2 : Introduction

2.1 Questions et Réponses

Q1 : What networking constructs are used to direct traffic to the right application on a server?

R : ports

Q2 : How many of these are available on any network-enabled computer?

R : 65535

Q3 : How many of these are considered "well-known"? (These are the "standard" numbers mentioned in the task)

R : 1024

2.2 Explication

Les ports sont des constructions réseau qui permettent de router le trafic vers la bonne application. Un serveur web écoute sur le port 80 (HTTP) ou 443 (HTTPS), tandis qu'un serveur SSH écoute sur le port 22.

3 Task 3 : Nmap Switches

3.1 Switches fondamentaux

Question	Réponse
What is the first switch listed in the help menu for a 'Syn Scan' ?	-sS
Which switch would you use for a "UDP scan" ?	-sU
If you wanted to detect which operating system the target is running on, which switch would you use ?	-O
Nmap provides a switch to detect the version of the services running on the target. What is this switch ?	-sV
The default output provided by nmap often does not provide enough information for a pentester. How would you increase the verbosity ?	-v
Verbosity level one is good, but verbosity level two is better! How would you set the verbosity level to two ?	-vv
We should always save the output of our scans. What switch would you use to save the nmap results in three major formats ?	-oA
What switch would you use to save the nmap results in a "normal" format ?	-oN
A very useful output format : how would you save results in a "grepable" format ?	-oG
Sometimes the results we're getting just aren't enough. How would you activate "aggressive" mode ?	-A
Nmap offers five levels of "timing" templates. How would you set the timing template to level 5 ?	-T5
How would you tell nmap to only scan port 80 ?	-p 80
How would you tell nmap to scan ports 1000-1500 ?	-p 1000-1500
How would you tell nmap to scan all ports ?	-p-
How would you activate a script from the nmap scripting library ?	--script
How would you activate all of the scripts in the "vuln" category ?	--script=vuln

3.2 Récapitulatif des switches importants

```
# Switches de scan
-sS # Scan SYN (stealth/half-open)
-sT # Scan TCP Connect
-sU # Scan UDP
-sN # Scan NULL
-sF # Scan FIN
```

```
-sX # Scan Xmas

# Detection
-O # Detection OS
-sV # Detection versions services
-A # Mode agressif (OS + versions + scripts + traceroute)

# Verbosity et output
-v # Verbosity niveau 1
-vv # Verbosity niveau 2
-oA # Output tous formats
-oN # Output normal
-oG # Output greppable

# Ports
-p 80 # Port spécifique
-p 1-1000 # Range de ports
-p- # Tous les ports (1-65535)

# Timing
-T0 # Paranoid (tres lent)
-T1 # Sneaky
-T2 # Polite
-T3 # Normal (default)
-T4 # Aggressive
-T5 # Insane (tres rapide)

# Scripts NSE
--script=<nom> # Script spécifique
--script=vuln # Categorie vuln
--script=safe # Categorie safe
```

4 Task 4 : Scan Types Overview

4.1 Questions et Réponses

Q1 : Read the Scan Types Introduction.

R : No answer needed

Q2 : Which RFC defines the appropriate behaviour for the TCP protocol ?

R : RFC 793

Q3 : If a port is closed, which flag should the server send back to indicate this ?

R : RST

4.2 TCP Three-Way Handshake

Le protocole TCP utilise un "three-way handshake" pour établir une connexion :

1. **SYN** : Le client envoie un paquet SYN
2. **SYN/ACK** : Le serveur répond avec SYN/ACK si le port est ouvert
3. **ACK** : Le client confirme avec ACK

Comportement des ports :

Port ouvert : Répond avec SYN/ACK

Port fermé : Répond avec RST (Reset)

Port filtré : Pas de réponse (firewall)

5 Task 5 : TCP Connect Scans (-sT)

5.1 Questions et Réponses

Q1 : Which RFC defines the appropriate behaviour for the TCP protocol ?

R : RFC 793

Q2 : If a port is closed, which flag should the server send back to indicate this ?

R : RST

5.2 Explication du TCP Connect Scan

Le scan TCP Connect (-sT) effectue le three-way handshake complet :

```
nmap -sT <cible>
```

- Complète la connexion TCP entièrement
- Plus lent que le SYN scan
- Plus facilement détectable dans les logs
- Ne nécessite pas de privilèges root
- Utilisé par défaut si pas de privilèges sudo

6 Task 6 : SYN Scans (-sS)

6.1 Questions et Réponses

Q1 : There are two other names for a SYN scan, what are they ?

R : Half-open, Stealth

Q2 : Can Nmap use a SYN scan without Sudo permissions (Y/N) ?

R : N

6.2 Explication du SYN Scan

Le scan SYN (-sS) est le scan par défaut avec privilèges root :

```
sudo nmap -sS <cible>
```

Avantages du SYN Scan :

- Plus rapide que TCP Connect
- Plus discret (ne complète pas la connexion)
- Moins susceptible d'être loggé par les applications
- Appelé "Half-open" car n'envoie pas le ACK final
- Appelé "Stealth" car plus difficile à détecter

Processus :

1. Envoie SYN
2. Reçoit SYN/ACK (port ouvert) ou RST (port fermé)
3. Envoie RST pour fermer (pas de ACK)

7 Task 7 : UDP Scans (-sU)

7.1 Questions et Réponses

Q1 : If a UDP port doesn't respond to an Nmap scan, what will it be marked as ?

R : open|filtered

Q2 : When a UDP port is closed, by convention the target should send back a "port unreachable" message. Which protocol would it use to do so ?

R : ICMP

7.2 Explication du UDP Scan

```
sudo nmap -sU <cible>
```

Caractéristiques UDP :

- UDP est "stateless" (pas de connexion)
- Beaucoup plus lent que les scans TCP
- Pas de réponse = port ouvert OU filtré
- Port fermé = message ICMP "port unreachable"
- Recommandé : scanner les 20 ports UDP les plus communs

```
# Scan UDP des ports les plus communs  
sudo nmap -sU --top-ports 20 <cible>
```

8 Task 8 : NULL, FIN and Xmas Scans

8.1 Questions et Réponses

Q1 : Which of the three shown scan types uses the URG flag ?

R : xmas

Q2 : Why are NULL, FIN and Xmas scans generally used ?

R : Firewall Evasion

Q3 : Which common OS may respond to a NULL, FIN or Xmas scan with a RST for every port ?

R : Microsoft Windows

8.2 Explication des scans

```
# NULL Scan - aucun flag
nmap -sN <cible>

# FIN Scan - flag FIN
nmap -sF <cible>

# Xmas Scan - flags PSH, URG, FIN
nmap -sX <cible>
```

Flags utilisés :

NULL (-sN) : Aucun flag

FIN (-sF) : Flag FIN uniquement

Xmas (-sX) : Flags PSH + URG + FIN (ressemble à un arbre de Noël)

Comportement attendu (RFC 793) :

— Port ouvert : pas de réponse

— Port fermé : RST

Limitation : Microsoft Windows répond avec RST pour tous les ports (ne suit pas RFC 793).

9 Task 9 : ICMP Network Scanning

9.1 Questions et Réponses

Q1 : How would you perform a ping sweep on the 172.16.x.x network (Netmask : 255.255.0.0) using Nmap? (CIDR notation)

R : `nmap -sn 172.16.0.0/16`

9.2 Ping Sweep

Un ping sweep permet de découvrir les hôtes actifs sur un réseau :

```
# Ping sweep sur un reseau /24
nmap -sn 192.168.1.0/24
```

```
# Ping sweep sur un reseau /16
nmap -sn 172.16.0.0/16
```

```
# Ping sweep sur un reseau /8
nmap -sn 10.0.0.0/8
```

Option -sn :

Effectue uniquement la découverte d'hôtes sans scanner les ports. Envoie des requêtes ICMP echo, TCP SYN sur le port 443, TCP ACK sur le port 80, et ICMP timestamp.

10 Task 10 : NSE Scripts Overview

10.1 Questions et Réponses

Q1 : What language are NSE scripts written in ?

R : Lua

Q2 : Which category of scripts would be a very bad idea to run in a production environment ?

R : intrusive

10.2 Nmap Scripting Engine (NSE)

Le NSE étend considérablement les capacités de Nmap avec des scripts Lua.

Catégories de scripts :

Catégorie	Description
auth	Tentatives de bypass d'authentification
broadcast	Découverte d'hôtes via broadcast
brute	Attaques par force brute
default	Scripts par défaut (-sC)
discovery	Découverte d'informations réseau
dos	Attaques de déni de service
exploit	Exploitation de vulnérabilités
external	Requêtes vers des services externes
fuzzer	Fuzzing de services
intrusive	Scripts intrusifs (dangereux en production)
malware	Détection de malware
safe	Scripts sûrs
version	Détection avancée de versions
vuln	Détection de vulnérabilités

11 Task 11 : NSE Scripts - Working with the NSE

11.1 Questions et Réponses

Q1 : What optional argument can the ftp-anon.nse script take ?

R : maxlist

11.2 Utilisation des scripts NSE

```
# Executer un script spécifique
nmap --script=<nom_script> <cible>

# Executer plusieurs scripts
nmap --script=script1,script2 <cible>

# Executer une categorie
nmap --script=vuln <cible>

# Scripts par défaut
nmap -sC <cible>
# équivalent à
nmap --script=default <cible>

# Passer des arguments aux scripts
nmap --script=ftp-anon --script-args maxlist=10 <cible>
```

Localisation des scripts :

```
/usr/share/nmap/scripts/
```

12 Task 12 : NSE Scripts - Searching for Scripts

12.1 Questions et Réponses

Q1 : Search for "smb" scripts in the /usr/share/nmap/scripts/ directory using either of the demonstrated methods. What is the filename of the script which determines the underlying OS of the SMB server?

R : smb-os-discovery.nse

Q2 : Read through this script. What does it depend on?

R : smb-brute

12.2 Recherche de scripts

```
# Methode 1 : ls avec wildcard
ls /usr/share/nmap/scripts/*smb*

# Methode 2 : grep dans script.db
grep "smb" /usr/share/nmap/scripts/script.db

# Methode 3 : locate
locate *.nse | grep smb

# Lire le contenu d'un script
cat /usr/share/nmap/scripts/smb-os-discovery.nse
```

Scripts SMB utiles :

- smb-os-discovery.nse - Détecte l'OS via SMB
- smb-enum-shares.nse - Énumère les partages
- smb-enum-users.nse - Énumère les utilisateurs
- smb-vuln-*.nse - Détecte les vulnérabilités SMB

13 Task 13 : Firewall Evasion

13.1 Questions et Réponses

Q1 : Which simple (and frequently relied upon) protocol is often blocked, requiring the use of the `-Pn` switch ?

R : ICMP

Q2 : [Research] Which Nmap switch allows you to append an arbitrary length of random data to the end of packets ?

R : `--data-length`

13.2 Techniques d'évasion de pare-feu

```
# Ignorer la decouverte d'hotes (pas de ping)
nmap -Pn <cible>

# Fragmenter les paquets
nmap -f <cible>

# MTU personnalisée (multiple de 8)
nmap --mtu 24 <cible>

# Ajouter des données aléatoires
nmap --data-length 200 <cible>

# Scan depuis des ports source spécifiques
nmap --source-port 53 <cible>
nmap -g 53 <cible>

# Utiliser des decoys (leurre)
nmap -D RND:5 <cible>
nmap -D decoy1,decoy2,ME <cible>

# Spoofing MAC
nmap --spoof-mac 0 <cible>
```

Option `-Pn` importante :

Windows bloque souvent ICMP par défaut. Si un hôte ne répond pas au ping mais que vous savez qu'il est actif, utilisez `-Pn` pour ignorer la découverte d'hôtes et scanner directement les ports.

14 Task 14 : Practical

14.1 Questions et Réponses

Q1 : Does the target (MACHINE_IP) respond to ICMP (ping) requests (Y/N) ?

R : N

Q2 : Perform an Xmas scan on the first 999 ports of the target – how many ports are shown to be open or filtered ?

R : 999

Q3 : There is a reason given for this – what is it ?

R : No Response

Q4 : Perform a TCP SYN scan on the first 5000 ports of the target – how many ports are shown to be open ?

R : 5

Q5 : Open Wireshark and perform a TCP Connect scan against port 80 on the target, monitoring the results.

R : No answer needed

Q6 : Deploy the ftp-anon script against the box. Can Nmap login successfully to the FTP server on port 21 ? (Y/N)

R : Y

14.2 Commandes utilisées

```
# Test ICMP
ping <MACHINE_IP>
# Resultat : pas de reponse (ICMP bloque)

# Xmas scan sur les premiers 999 ports
nmap -sX -p 1-999 <MACHINE_IP>
# Resultat : 999 ports open|filtered

# SYN scan sur les premiers 5000 ports
sudo nmap -sS -p 1-5000 <MACHINE_IP>
# Resultat : 5 ports ouverts

# TCP Connect scan sur port 80 (avec Wireshark)
nmap -sT -p 80 <MACHINE_IP>

# Script ftp-anon
nmap --script=ftp-anon -p 21 <MACHINE_IP>
# Resultat : Anonymous FTP login allowed
```

15 Task 15 : Conclusion

15.1 Résumé des compétences acquises

Compétences développées :

- Comprendre le fonctionnement des ports et du protocole TCP
- Maîtriser les différents types de scans Nmap
- Utiliser les switches et options de manière efficace
- Exploiter le Nmap Scripting Engine (NSE)
- Appliquer des techniques d'évasion de pare-feu
- Effectuer des scans pratiques sur des cibles réelles

15.2 Commandes essentielles à retenir

```
# Scan complet standard
sudo nmap -sC -sV -O -p- <cible>

# Scan rapide
nmap -T4 -F <cible>

# Scan furtif
sudo nmap -sS -T2 -f <cible>

# Scan de vulnérabilités
nmap --script=vuln <cible>

# Ping sweep
nmap -sn 192.168.1.0/24

# Scan UDP
sudo nmap -sU --top-ports 20 <cible>

# Evasion firewall
nmap -Pn -sS -T4 <cible>
```

16 Annexes

16.1 Annexe A : Cheat Sheet Nmap

Types de scans :

```
-sS # SYN scan (stealth)
-sT # TCP Connect scan
-sU # UDP scan
-sN # NULL scan
-sF # FIN scan
-sX # Xmas scan
-sA # ACK scan
-sW # Window scan
-sM # Maimon scan
```

Découverte d'hôtes :

```
-sn # Ping scan (pas de port scan)
-Pn # Pas de ping (traiter comme actif)
-PS<ports> # TCP SYN ping
-PA<ports> # TCP ACK ping
-PU<ports> # UDP ping
-PE # ICMP echo ping
-PP # ICMP timestamp ping
```

Spécification de ports :

```
-p 80 # Port unique
-p 80,443 # Plusieurs ports
-p 1-1000 # Range de ports
-p- # Tous les ports (1-65535)
-p U:53,T:80 # UDP 53, TCP 80
--top-ports N # Les N ports les plus communs
```

16.2 Annexe B : Ressources

- Documentation Nmap : <https://nmap.org/docs.html>
- NSE Documentation : <https://nmap.org/nsedoc/>
- TryHackMe Room : <https://tryhackme.com/room/furthernmap>
- Nmap Cheat Sheet : <https://www.stationx.net/nmap-cheat-sheet/>

Notes importantes

❑ Avertissement légal

L'utilisation de Nmap pour scanner des systèmes sans autorisation explicite est illégale dans de nombreuses juridictions. Les techniques décrites dans ce rapport ne doivent être utilisées que :

- Sur vos propres systèmes
- Dans des environnements de lab autorisés (TryHackMe, HackTheBox, etc.)
- Avec une autorisation écrite explicite du propriétaire

L'auteur de ce rapport décline toute responsabilité en cas d'utilisation abusive de ces techniques.

Room complété avec succès

TryHackMe - Nmap (Further Nmap)

Ibrahim Kakaev
Décembre 2025

Dans le cadre d'une formation en cybersécurité